

PHISHING EMAIL DETECTION & AWARENESS REPORT

Cyber Security Task 2 (2026)

Phishing Analysis & Employee Awareness Program

Prepared by: **[Your Name]**

Program: Future Interns — Cyber Security Task 2 (2026)

Date: **[Submission Date]**

A practical security-awareness report focused on identifying phishing indicators, classifying email risk, and helping employees respond safely.

1. Introduction

Phishing remains one of the most common and costly cyber attacks facing businesses and individuals today. Attackers use deceptive emails to trick users into clicking malicious links, downloading infected attachments, or handing over passwords, one-time codes, and financial information.

Most successful phishing attacks succeed not because of weak technical systems, but because users are not equipped to recognize the warning signs of a fake email. This is why organizations invest in phishing email analysis, employee awareness training, and internal security guidelines.

This report analyzes six public phishing email samples, identifies the common indicators attackers rely on, classifies each sample's risk level, and translates the findings into practical guidance that employees can use to protect themselves and the organization.

Objective

- Analyze real phishing email samples collected from public datasets.
- Identify common phishing indicators across header, sender, and content data.
- Classify each email's risk level clearly (Safe / Suspicious / Phishing).
- Explain how each attack works in simple, non-technical language.
- Produce prevention guidelines and a Do's & Don'ts reference for employees.

Tools Used

- Public phishing email samples (rf-peixoto/phishing_pot dataset).
- Email Header Analyzer — Google Message Header Analyzer.
- MxToolbox Email Header Analyzer.
- Manual link/domain inspection (no links clicked).
- Word processor for report documentation.

2. Methodology

- **Header Analysis** — checking From, Return-Path, Reply-To, and Received chains; verifying SPF, DKIM, and DMARC authentication results.
- **Link & Domain Inspection** — identifying the true destination of links or buttons without clicking them, and comparing sender domains against the brand being impersonated.
- **Indicator Checklist** — recording every phishing red flag present, with supporting evidence from the message.
- **Risk Classification** — assigning a Safe / Suspicious / Phishing label with a short justification.
- **Plain-English Explanation** — describing how the attack works for a non-technical reader.

3. Analyzed Phishing Samples

Six email samples were analyzed, covering credential-harvesting phishing, brand impersonation, advance-fee fraud, and borderline commercial spam.

Sample 1: Fake Account Verification (Generic Template)

Subject: ■■ Urgent: Your Account Will Be Locked

From (displayed): "Security Team" (no company name given)

From (actual domain): N/A — sample provided as body text only

Return-Path / Reply-To: N/A

Indicator	Present? / Evidence
Urgency / fear language	Yes — "Urgent," "24 hours," "permanent lock"
Generic greeting	Yes — "Dear User" instead of a real name
Suspicious / lookalike domain	Yes — secure-account-verify[.]com
Vague / unnamed sender	Yes — signed only "Security Team"
Pressure-driven call to action	Yes — immediate click required to avoid suspension
Spelling / grammar errors	No — none obvious in this sample

Risk Classification: Phishing (High Confidence)

Plain-English Explanation

This email tries to scare the reader into thinking their account is at risk so they click without thinking. The link goes to a fake page built to look like a real login screen — anything typed there (username, password) goes straight to the attacker.

Sample 2: Fake Microsoft "Unusual Sign-in Activity" Alert

Subject: Microsoft account unusual signin activity

From (displayed): "Microsoft account team"

From (actual domain): u6x5m@mf2g7kdiqv.com

Return-Path / Reply-To: bounce@bynatdeelie.co.uk / assistant.support0rt.acc0unt@gmail.com

Indicator	Present? / Evidence
Sender domain mismatch	Yes — display name says Microsoft; real domain is mf2g7kdiqv.com
Failed SPF / DKIM / DMARC	Yes — all three failed per headers
Urgency / fear language	Yes — "Unusual sign-in," flagged foreign country
Fake action link	Yes — "Report The User" routes to a Gmail address
Hidden tracking pixel	Yes — invisible 1px image beacon
Lookalike free-mail reply address	Yes — Gmail address using 0-for-o substitution

Risk Classification: Phishing (High Confidence)

Plain-English Explanation

This email pretends to be a Microsoft security alert saying someone in Russia logged into your account. The "Report The User" button does not go to Microsoft; it sends an email to the attacker. Opening the email can also confirm that the address is active for further targeting.

Sample 3: Fake PayPal “\$90 Exclusive Offer”

Subject: Re: 2nd attempt for [recipient]

From (displayed): "Paypal"

From (actual domain): 0a7pz@poumzenuhs.com

Return-Path: lrvls04@lsvaim.net

Indicator	Present? / Evidence
Sender / domain mismatch	Yes — “Paypal” display name; real domain poumzenuhs.com
Failed SPF / DKIM / DMARC	Yes — all failed per headers
Too-good-to-be-true offer	Yes — “Exclusive \$90 offer”
Obfuscated link via URL shortener	Yes — all links routed through t.co
Junk / garbled footer text	Yes — random word list appended, likely spam-filter evasion

Risk Classification: Phishing (High Confidence)

Plain-English Explanation

This message pretends to be PayPal offering free money to bait a click on a disguised link. Because the real destination is hidden behind a shortener, there is no way to verify safety before clicking — which is exactly the point.

Sample 4: “Widow’s Inheritance” Advance-Fee Scam

Subject: Hi

From (displayed): shore@suksapan.or.th

From (actual domain): suksapan.or.th

Reply-To: elizabethray993@gmail.com

Indicator	Present? / Evidence
Sender / reply-to mismatch	Yes — suksapan.or.th sends, but replies go to a personal Gmail
Failed / soft-failed SPF	Yes — SPF softfail on sending domain
Emotional manipulation	Yes — references terminal illness and a deceased spouse
Vague urgent financial proposal	Yes — “Partnership for Allocated Funds - Urgent Situation”
Asks for direct reply rather than a link	Yes — “reply to this email for more details”

Risk Classification: Phishing / Scam (High Confidence)

Plain-English Explanation

This message preys on sympathy and greed rather than using a malicious link. Once a recipient replies, the attacker can escalate the relationship and eventually request processing fees or banking details to release fictitious funds.

Sample 5: Unsolicited Dutch Solar Panel Advertisement

Subject: ■ Zonnepanelen voor een goede prijs

From (displayed): "Zonnepanelen installateur"

From (actual domain): zonnepaneel@appjj.serenitepure.fr

Return-Path / Reply-To: return@dturm.de / news@aichakandisha.com

Indicator	Present? / Evidence
Multiple mismatched sending domains	Yes — four unrelated domains across From / Reply-To / Return-Path
Failed SPF / DMARC	Yes — SPF none, DMARC fail
Unsolicited commercial content	Yes — unrequested sales pitch
Redirect / tracking link	Yes — links routed through go.nltrck.com
Requests credentials or payment info	No — no credential or payment request present

Risk Classification: Suspicious

Plain-English Explanation

This is an unsolicited ad for solar panel quotes, routed through disposable domains and a tracking redirector. Even if the goal is only to generate a sales lead, the sending infrastructure is built similarly to phishing campaigns, so it merits caution.

Sample 6: Fake Bradesco Bank “Points Expiring Today” Alert

Subject: CLIENTE PRIME - BRADESCO LIVELO: Seu cartão tem 92.990 pontos LIVELO expirando hoje!

From (displayed): "BANCO DO BRADESCO LIVELO"

From (actual domain): banco.bradesco@atendimento.com.br

Return-Path / Reply-To: root@ubuntu-s-1vcpu-1gb-35gb-intel-sfo3-06

Indicator	Present? / Evidence
Sent from generic cloud VPS, not a bank	Yes — generic cloud-hosting hostname in Received headers
Failed / errored authentication	Yes — SPF temperror, DMARC fail
Urgency language	Yes — “Points expire TODAY”
Spoofed brand identity	Yes — impersonates Bradesco / Livelo rewards program
Suspicious redemption link domain	Yes — blog1seguimentmydomaine2bra.me
Obfuscated body content	Yes — Base64-encoded HTML body

Risk Classification: Phishing (High Confidence)

Plain-English Explanation

This message pretends to be Bradesco Bank warning that rewards points expire today, pressuring the reader to click and redeem immediately. The link leads to a fake login page designed to steal banking credentials, not a real Bradesco site.

4. Summary of Findings

Sample	Classification	Primary Technique
1. Fake Account Verification	Phishing	Urgency-based credential phishing
2. Fake Microsoft Alert	Phishing	Brand impersonation + tracking pixel
3. Fake PayPal Offer	Phishing	Brand impersonation via link shortener
4. Widow's Inheritance	Phishing / Scam	Advance-fee / emotional manipulation scam
5. Dutch Solar Advertisement	Suspicious	Spoofed-domain commercial spam
6. Fake Bradesco Alert	Phishing	Brand impersonation + obfuscated payload

Common Patterns Observed

- Sender display name almost never matches the actual sending domain.
- Failed or missing SPF, DKIM, and DMARC results appeared in every phishing sample.
- Urgency and fear (“expires today,” “account locked,” “unusual activity”) is used to short-circuit careful reading.
- Legitimate-sounding brand names are paired with unrelated or randomly generated domains.
- Link shorteners, redirectors, and mailto links are used to hide or misdirect the true destination.

5. Prevention Guidelines

How to Spot a Phishing Email

- Check the sender's actual email address, not just the display name — hover over or tap the name to reveal it.
- Be suspicious of any message creating urgency or fear (“act now,” “account will be locked,” “expires today”).
- Never click a link before checking where it actually leads — preview the URL and watch for lookalike or shortened domains.
- Be wary of generic greetings (“Dear User”) from organizations that would normally use your real name.
- Treat unexpected attachments, especially from unknown senders, as untrusted by default.
- Remember that legitimate banks, tech companies, and services will never ask for your password or OTP by email.

Do's and Don'ts for Employees

✓ DO	✗ DON'T
Verify sender addresses before acting on any request	Don't trust a display name alone — it can say anything
Report suspicious emails to IT/Security immediately	Don't click links or open attachments from unknown senders
Use multi-factor authentication wherever available	Don't reuse passwords across personal and work accounts
Type company URLs directly into the browser when in doubt	Don't reply to unsolicited requests for money or personal data
Pause before acting on urgent or emotional requests	Don't assume internal-looking emails are automatically safe

6. Conclusion

The analyzed samples show that phishing relies far more on psychological manipulation — urgency, fear, sympathy, and impersonation of trusted brands — than on technical sophistication. In every phishing case examined, basic checks such as verifying the sending domain, checking SPF/DKIM/DMARC results, and

inspecting link destinations before clicking would have exposed the attack.

Ongoing employee awareness, combined with straightforward technical checks, remains the most effective defense against phishing — far more so than relying on filtering technology alone.

Recommended Awareness Workflow

- **Pause:** Do not act immediately on urgent or emotional requests.
- **Inspect:** Check the sender address, authentication results, and link destination.
- **Classify:** Mark the message Safe, Suspicious, or Phishing based on the evidence.
- **Report:** Send suspicious messages to the organization's IT/Security team.
- **Educate:** Share recurring indicators with employees to reduce repeat exposure.